

SAMPLE GRATUIT / EDIȚIA 2026

EVALUAREA SECURITĂȚII REȚELEI

Exemplu de raport executiv & tehnic

ASSESS -> FIX -> VALIDATE -> PROVE

Organizație fictivă. Dovezi sintetice. Exclusiv pentru demonstrație. Nu este reprezentat niciun mediu de client sau de producție.

WeOwnIT / Network & Security Consulting

Risk-informed security engineering · Architecture · Remediation · Validation

Sumar executiv al evaluării

De la constatări tehnice la risc de business și remediere validată.

CONCLUZIA EVALUĂRII

Mediul sintetic prezintă slăbiciuni frecvente privind protecția planului de management, segmentarea rețelei, accesul privilegiat și vizibilitatea de securitate. Riscul principal rezultă din combinația dintre reachability extins, expunere privilegiată și monitorizare incompletă.

RISC PENTRU BUSINESS

Un endpoint compromis din zona de utilizatori poate crea o cale către controlul privilegiat al rețelei. Accesul east-west excesiv crește posibilitatea de lateral movement, iar logarea incompletă poate reduce capacitatea de detecție și investigație.

REZULTAT

Exemplul arată cum WeOwnIT leagă dovezile de impactul de business, ownership-ul remedierii, criteriile de validare și riscul rezidual - nu doar de o listă de finding-uri.

Context de business & active critice

Deciziile de securitate pornesc de la ceea ce susține business-ul.

CONTEXT

ACME Manufacturing este o organizație fictivă cu 250 de utilizatori, sediu central, două filiale, ERP critic, servicii interne, conectivitate remote și management centralizat de securitate.

ACTIVE CRITICE

Firewall de Internet; rețea de management; servere ERP și aplicații; conectivitate VPN; logare centralizată; identități administrative.

OBJECTIVE DE SECURITATE

Disponibilitatea conectivității, integritatea configurațiilor privilegiate, confidențialitatea datelor, segmentarea trust zones și trasabilitatea acțiunilor administrative.

Scope, ipoteze & metodologie

Model repetabil pentru engineering bazat pe risc.

SCOPE

Arhitectură, trust boundaries, expunere administrativă, segmentare, politici firewall, logare, acces privilegiat, backup și recovery.

METODĂ

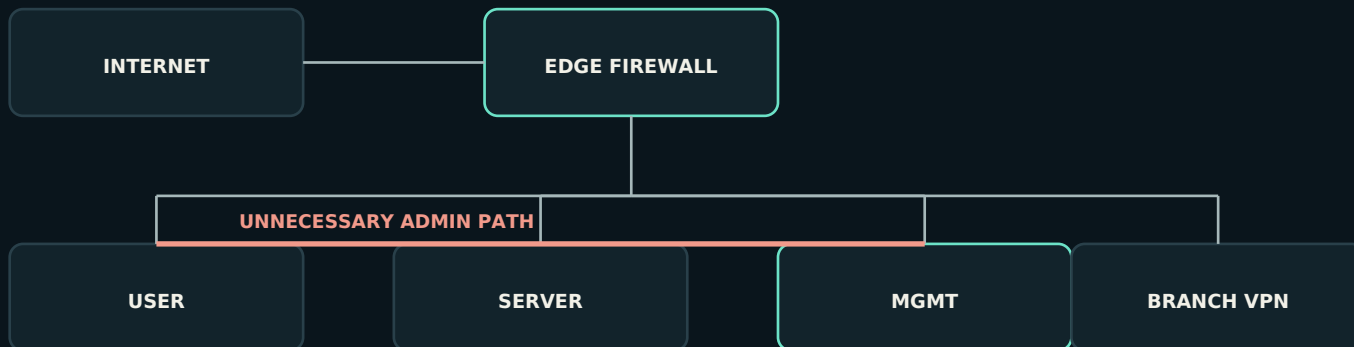
CONTEXT -> ASSESS -> ANALYZE -> PRIORITIZE -> REMEDIATE -> VALIDATE -> PROVE

ÎNCREDEREA ÎN DOVEZI

Acest sample folosește dovezi SINTETICE / INFERATE. Într-un engagement real, dovezile sunt clasificate Confirmed, Observed, Inferred sau Not Tested.

Arhitectură & trust boundaries

Unde zonele cu încredere redusă pot ajunge la control privilegiat.



TRUST ZONES

Internet / User / Server / Management / Security Management / Branch VPN

PROBLEMĂ DE TRUST

Zona sintetică User poate ajunge la HTTPS/SSH administrativ pe firewall. Astfel apare o cale inutilă de atac de la un segment workstation cu trust redus către un control de securitate privilegiat.

TARGET STATE

Administrarea pornește doar din zona de management sau dintr-un traseu remote aprobat, protejat prin MFA, conturi nominale, least privilege și logare centralizată.

Registru de riscuri & prioritzare

Prioritizăm scenarii, nu setări izolate.

R-01 - EXPUNERE MANAGEMENT PLANE

Likelihood 4/5 | Impact 5/5 | Risc inerent: CRITICAL | Risc rezidual țintă: LOW

R-02 - ACCES EAST-WEST EXCESIV

Likelihood 4/5 | Impact 4/5 | Risc inerent: HIGH | Risc rezidual țintă: MEDIUM

R-03 - LOGARE INCOMPLETĂ

Likelihood 3/5 | Impact 4/5 | Risc inerent: HIGH | Risc rezidual țintă: LOW

R-04 - ACCES PRIVILEGIAT FĂRĂ MFA

Likelihood 3/5 | Impact 5/5 | Risc inerent: HIGH | Risc rezidual țintă: LOW

1	2	3	4	5
2	4	6	8	10
3	6	9	12	15
4	8	12	16	
5	10	15	20	25

F-001 - Management plane accesibil din zona User

Finding detaliat - HIGH

ATTACK PATH

Compromised endpoint -> User zone -> Firewall management -> Privileged control

ACTIV AFECTAT

Edge firewall / management plane

OBSERVAȚIE

Serviciile administrative HTTPS și SSH sunt accesibile din rețeaua generală de utilizatori.

SCENARIU DE AMENINȚARE

Un endpoint compromis poate obține conectivitate către management plane. Combinat cu compromiterea credentialelor sau altă slăbiciune de autentificare, acest lucru creează o cale către control privilegiat.

DOVEZI ILUSTRATIVE

Sursă 10.20.10.25 (USER) -> 10.20.100.1 TCP/443 REACHABLE; TCP/22 REACHABLE.

IMPACT POTENȚIAL

Modificări neautorizate de politici, VPN sau routing; ocolirea controalelor; modificarea logării; întreruperea serviciilor.

F-001 - Strategie de control & validare

Previne, limitează, detectează, recuperează - apoi demonstrează.

ATTACK PATH

Compromised endpoint -> User zone -> Firewall management -> Privileged control

PREVENT

Rețea dedicată de management; surse administrative trusted; MFA; conturi nominale.

LIMIT

Roluri administrative RBAC; least privilege; protocoale de management restricționate.

DETECT

Logare autentificări administrative, eșecuri și schimbări de configurație.

RECOVER

Backup de configurație validat și cale de recovery documentată.

RISC DE IMPLEMENTARE

MEDIUM - modificarea accesului de management fără conectivitate alternativă poate produce lockout. Validează întâi console/OOB.

DOVEZI DE VALIDARE

MGMT -> HTTPS ALLOW; USER -> HTTPS BLOCK; WAN -> SSH BLOCK; MFA VERIFIED; evenimente administrative vizibile în logarea centrală.

RISC REZIDUAL ESTIMAT

LOW dacă sursele de acces, MFA, conturile nominale și logarea centralizată sunt verificate.

F-002 - Acces east-west excesiv

Finding detaliat - HIGH

OBSERVAȚIE

O politică largă User-to-Server permite mai multe servicii decât sunt necesare operațional.

SCENARIU

Un workstation compromis poate obține reachability inutilă către workload-uri interne și poate crește posibilitatea de lateral movement.

STARE CURENTĂ

USER -> SERVER : acces larg / any-style

TARGET STATE

USER -> APP : doar servicii de business necesare; USER -> DB/MGMT : deny fără justificare explicită.

VALIDARE

Test pozitiv pentru fluxul aplicației și teste negative pentru porturi de database și management; review pe logurile traficului blocat.

RISC REZIDUAL

MEDIUM după least-privilege și monitorizare, în funcție de dependențe și excepții aprobate.

Roadmap de remediere & dovezi de închidere

Transformăm finding-urile în acțiuni măsurabile și asumate.

0-7 ZILE

F-001 expunere management - Network Security - efort redus / risc de change mediu.

0-30 ZILE

F-002 reducere politici - Network Security + Application Owner - efort mediu. Impune MFA pentru conturi privilegiate.

30-60 ZILE

Centralizează logarea și verifică acoperirea evenimentelor administrative. Validează backup/recovery.

CRITERII DE ÎNCHIDERE

OPEN -> REMEDIATION PLANNED -> IMPLEMENTED -> VALIDATION REQUIRED -> VERIFIED -> CLOSED.

EVIDENCE PACK

Configurație, change aprobat, teste pozitive/negative, dovadă în loguri, risc rezidual și acceptare de owner.

REZULTAT PENTRU CLIENT

Executive summary + findings tehnice + remediation backlog + target architecture + validation plan + evidence reutilizabil.